

RELATÓRIO DE VULNERABILIDADES

Projeto NockHug

Sistema de acionamento remoto por comando de voz para máquina lançadora (protótipo em máquina de lançar bolinhas de ping pong)

FUNDAÇÃO ESCOLA DE COMÉRCIO ÁLVARES PENTEADO - FECAP

Bacharelado em Ciência da Computação

Redes de Computadores e Cibersegurança – Victor Rosseti

Estudantes:

- André Gregório dos Santos – RA: 24026489
- Guilherme Reis Fogolin de Godoy – RA: 24026241
- Pedro Henrique Nascimento Lemos – RA: 23025380
- Yan Ramos Cezareto – RA: 24026005

Turma: 6NACOMP_S

Data: 25/09/2026 **Versão:** 1.0

1. Introdução

Este documento descreve como o gerenciamento de vulnerabilidades foi estruturado e realizado para o projeto NockHug. O objetivo é identificar, analisar e priorizar as vulnerabilidades técnicas e arquiteturais do sistema, propor respostas de mitigação e implementar controles de segurança iniciais, de modo a aumentar a probabilidade de sucesso do projeto e reduzir o risco de exploração indevida do sistema.

O NockHug é um projeto desenvolvido em parceria entre a FECAP e uma empresa de desenvolvimento de máquinas lançadoras de bolas de tênis, com o objetivo de permitir ligar e desligar a máquina remotamente apenas por comando de voz ("Ligar" e "Desligar"). Para fins de desenvolvimento e apresentação, a solução está sendo prototipada em uma máquina de lançar bolinhas de ping pong, que simula o comportamento da máquina de bolas de tênis e já possui implementada a funcionalidade de acionamento por voz.

A arquitetura atual é composta por um microcontrolador ESP32 que cria uma rede Wi-Fi própria (modo Access Point) e hospeda uma página web. Essa página utiliza a API de reconhecimento de voz do navegador (Web Speech API) para interpretar os comandos "ligar" e "desligar" e, em seguida, envia requisições HTTP para o ESP32, que aciona os motores por meio de um módulo MOSFET (lançador) e um módulo IRF520 (alimentador).

2. Metodologia

A abordagem para o gerenciamento de vulnerabilidades neste projeto foi a seguinte:

- **Identificação de Vulnerabilidades:** as vulnerabilidades foram identificadas por meio de revisão manual do código-fonte do firmware (ESP32/Arduino) e da página web embarcada, análise da arquitetura de rede (modo de operação Wi-Fi, endpoints HTTP expostos) e análise do diagrama elétrico do circuito (fonte, conversor de tensão, MOSFET de acionamento e módulo de motor).
- **Análise de Vulnerabilidades:** cada vulnerabilidade identificada foi analisada qualitativamente para determinar sua probabilidade de exploração e o impacto sobre a confidencialidade, integridade e disponibilidade do sistema, seguindo a mesma escala de probabilidade e impacto adotada no Plano de Gerenciamento de Riscos do projeto (seções 6 e 7).
- **Planejamento de Respostas:** para cada vulnerabilidade significativa foi definida uma estratégia de resposta (mitigar, aceitar ou monitorar), incluindo, quando aplicável, a implementação de um controle de segurança inicial diretamente no código-fonte.
- **Monitoramento e Controle:** as vulnerabilidades identificadas e o status de suas mitigações são consolidados no Registro de Vulnerabilidades (seção 9) e serão reavaliados a cada marco do projeto, à medida que novas funcionalidades forem adicionadas.

3. Papéis e Responsabilidades

Papel	Responsabilidades no Gerenciamento de Vulnerabilidades
Equipe do Projeto (André, Guilherme, Pedro e Yan)	Realizar a revisão do código e da arquitetura, identificar vulnerabilidades, propor e implementar os controles de segurança iniciais, e manter este relatório atualizado.

Professor(a) / Avaliador(a) da disciplina	Orientar a metodologia de análise de vulnerabilidades, validar as entregas e apontar riscos não percebidos pela equipe.
Empresa parceira (fabricante da máquina de bolas de tênis)	Fornecer o contexto de uso real do equipamento e requisitos de segurança física/operacional a serem considerados na versão final do produto.
Demais partes interessadas (colegas de turma, avaliadores externos)	Tomar conhecimento das principais vulnerabilidades do projeto apresentadas durante a entrega.

4. Orçamento e Cronograma para Gerenciamento de Vulnerabilidades

Orçamento: não aplicável. Por se tratar de um projeto acadêmico, não há orçamento formal alocado; os controles de segurança propostos utilizam apenas recursos de software (código-fonte) já disponíveis no projeto.

Cronograma:

- Identificação inicial de vulnerabilidades: revisão do código e do circuito realizada até a presente versão do relatório.
- Implementação dos controles de segurança iniciais: concluída nesta entrega, com o código-fonte atualizado disponibilizado junto a esta entrega.
- Entrega do relatório de vulnerabilidades: 25/09/2026.
- Revisões futuras: a cada novo marco do projeto (ex.: migração do protótipo de ping pong para a máquina de bolas de tênis).

5. Categorias de Vulnerabilidades

As vulnerabilidades foram categorizadas da seguinte forma para facilitar a identificação e a análise:

- Técnicas (Rede e Software): relacionadas à autenticação, criptografia, exposição de endpoints HTTP, configuração de rede Wi-Fi e qualidade do firmware.
- Físicas / Elétricas: relacionadas ao circuito eletrônico (proteção contra sobrecorrente, isolamento, componentes de potência).
- Operacionais: relacionadas ao uso do sistema em campo, como exposição do comando de voz a terceiros não autorizados.
- Externas: relacionadas à dependência de serviços de terceiros, como a API de reconhecimento de voz do navegador (Web Speech API), fora do controle da equipe do projeto.

6. Definições de Probabilidade e Impacto

Probabilidade:

Nível	Descrição	Valor
Muito Alta	Exploração quase certa (falha trivial de explorar, sem barreiras)	> 80%
Alta	Exploração provável (requer pouco conhecimento técnico)	61% - 80%

Média	Exploração possível (requer algum conhecimento técnico ou acesso à rede)	41% - 60%
Baixa	Exploração improvável (requer acesso físico ou conhecimento avançado)	21% - 40%
Muito Baixa	Exploração muito improvável	< 20%

Impacto:

Nível	Descrição
Muito Alto	Compromete totalmente a operação do sistema (controle irrestrito dos motores) ou expõe dados/credenciais críticos
Alto	Permite controle não autorizado de funções do sistema (ligar/desligar a máquina remotamente)
Médio	Permite obter informações sobre o funcionamento do sistema ou interrompe parcialmente seu funcionamento
Baixo	Causa inconveniência limitada, sem controle sobre atuadores ou dados sensíveis
Muito Baixo	Impacto desprezível sobre a segurança ou operação do sistema

7. Matriz de Probabilidade e Impacto

Esta matriz foi utilizada para priorizar as vulnerabilidades identificadas na seção 9.

Prob. \ Impacto	Muito Baixo	Baixo	Médio	Alto	Muito Alto
Muito Alta	Médio	Alto	Alto	Extremo	Extremo
Alta	Baixo	Médio	Alto	Alto	Extremo
Média	Baixo	Médio	Médio	Alto	Alto
Baixa	Muito Baixo	Baixo	Baixo	Médio	Médio
Muito Baixa	Muito Baixo	Muito Baixo	Baixo	Baixo	Médio

- Extremo/Alto: requerem atenção imediata e um plano de resposta detalhado — priorizados para mitigação nesta entrega.
- Médio: devem ser monitorados de perto e mitigados nas próximas iterações do projeto.
- Baixo/Muito Baixo: serão monitorados como parte das atividades de rotina do projeto.

8. Tolerância a Vulnerabilidades das Partes Interessadas

Por se tratar de um protótipo acadêmico que aciona um atuador físico (motor) à distância, a equipe do projeto e a empresa parceira têm tolerância muito baixa a vulnerabilidades que permitam o acionamento não autorizado da máquina por terceiros, uma vez que isso representa risco de segurança física para pessoas próximas ao equipamento. Já vulnerabilidades que apenas expõem informações de status (como o endpoint /status) ou que exigem acesso físico próximo ao equipamento têm tolerância maior, podendo ser tratadas em iterações futuras do projeto, à medida que a solução evolui do protótipo de ping pong para a máquina de bolas de tênis em produção.

9. Formatos de Relatórios

Registro de Vulnerabilidades: consolidado na tabela abaixo, com os campos: identificador, descrição, categoria, probabilidade, impacto, nível de risco resultante (conforme a matriz da seção 7), resposta/controlado recomendado e status atual da mitigação.

ID	Vulnerabilidade	Categoria	Probabilidade	Impacto	Nível	Resposta / Controle recomendado	Status
V1	Senha do Access Point numérica e sequencial ("12345678"), suscetível a força bruta/dicionário	Técnica (Rede)	Alta	Alto	Alto	Substituir por senha forte (≥12 caracteres, alfanumérica com símbolo)	Mitigado nesta entrega
V2	Endpoints HTTP /ligar e /desligar aceitam qualquer requisição, sem autenticação	Técnica (Software)	Muito Alta	Alto	Extremo	Exigir token compartilhado (ou equivalente) em toda requisição que altere o estado do atuador	Mitigado (parcial) nesta entrega
V3	Comunicação em HTTP puro, sem criptografia (comandos trafegam em texto claro)	Técnica (Rede)	Média	Médio	Médio	Avaliar uso de HTTPS/TLS ou, no mínimo, ofuscação/assinatura da requisição	Em aberto
V4	Ausência de proteção contra repetição de requisição (replay) e CSRF	Técnica (Software)	Média	Médio	Médio	Adotar token de uso único (nonce) ou timestamp assinado por requisição	Em aberto
V5	SSID fixo e identificável ("ESP32_Voz_Direta"), facilita o reconhecimento do alvo	Técnica (Rede)	Alta	Baixo	Médio	Renomear o SSID para um nome não descritivo do sistema	Em aberto
V6	Reconhecimento de voz ocorre no navegador (cliente); o ESP32 não valida se o comando realmente se originou de um comando de voz autorizado, apenas do HTTP GET recebido	Técnica (Arquitetura)	Alta	Alto	Alto	Tratar a camada de voz apenas como UX; a autenticação real deve ocorrer no ESP32 (token/credencial), já parcialmente implementada nesta entrega	Mitigado (parcial) nesta entrega
V7	Ausência de limitação de requisições (rate limiting), permitindo flood dos endpoints	Técnica (Software)	Média	Médio	Médio	Implementar intervalo mínimo entre comandos aceitos	Mitigado nesta entrega
V8	Diagrama elétrico não evidencia fusível/proteção de sobrecorrente entre a fonte de 12V e os motores	Física/Elétrica	Baixa	Médio	Baixo	Avaliar inclusão de fusível ou proteção de sobrecorrente no circuito de potência	Em aberto

Relatório de Status: este documento constitui o relatório de status das vulnerabilidades identificadas até o momento, contemplando as versões original e atualizada (com os controles de segurança iniciais) do firmware do sistema, entregues em conjunto com este relatório.

10. Acompanhamento

O processo de gerenciamento de vulnerabilidades será revisado em cada marco importante do projeto — especialmente na transição do protótipo (máquina de lançar bolinhas de ping pong) para a máquina de bolas de tênis da empresa parceira — para garantir sua eficácia e incorporar lições aprendidas. O Registro de

Vulnerabilidades (seção 9) será um documento vivo, atualizado continuamente à medida que novas funcionalidades forem adicionadas ao sistema.

11. Controles de Segurança Iniciais Implementados

Conforme solicitado pela disciplina, foram implementados no código-fonte do projeto os seguintes controles de segurança iniciais, todos direcionados às vulnerabilidades de maior nível identificadas na seção 9:

- Autenticação por token compartilhado (V2, V6): os endpoints /ligar e /desligar passaram a exigir um parâmetro token na requisição HTTP, validado no ESP32 antes de qualquer acionamento do motor. Requisições sem o token correto recebem HTTP 401 (Não Autorizado).
- Rate limiting (V7): foi adicionado um intervalo mínimo de 1 segundo entre comandos aceitos, bloqueando com HTTP 429 requisições enviadas em sequência muito rápida, o que mitiga tentativas simples de flood/negação de serviço.
- Senha de rede Wi-Fi mais forte (V1): a senha do Access Point, antes numérica e sequencial, foi substituída por uma senha alfanumérica de 15 caracteres com símbolo, dificultando ataques de força bruta e dicionário.

Essas mudanças são controles iniciais e possuem limitações reconhecidas: o token permanece fixo (hardcoded) tanto no firmware quanto no HTML servido ao navegador, o tráfego continua em HTTP sem criptografia, e não há proteção formal contra reenvio de requisições capturadas (replay). Essas limitações permanecem registradas como vulnerabilidades em aberto (V3, V4, V5, V8) no Registro de Vulnerabilidades e deverão ser tratadas em iterações futuras, especialmente antes da migração do protótipo para a máquina de bolas de tênis em ambiente real de uso.

12. Conclusão

A análise de vulnerabilidades realizada sobre o projeto NockHug permitiu identificar oito vulnerabilidades no código-fonte e na arquitetura do sistema, distribuídas entre falhas técnicas de rede e software (autenticação, criptografia, configuração de Wi-Fi e ausência de limitação de requisições) e uma fragilidade física relacionada à proteção elétrica do circuito. A aplicação da matriz de probabilidade e impacto evidenciou que as vulnerabilidades mais críticas (V2, extrema, e V1 e V6, altas) estavam justamente relacionadas ao ponto central do projeto: o acionamento remoto dos motores, que até então podia ser feito por qualquer dispositivo conectado à rede do ESP32, sem qualquer verificação real de autorização.

Com base nesse diagnóstico, foram implementados no código-fonte três controles de segurança iniciais — autenticação por token compartilhado, limitação de requisições (rate limiting) e uma senha de rede Wi-Fi mais robusta —, que mitigam total ou parcialmente as vulnerabilidades de maior nível (V1, V2, V6 e V7). Essas mudanças mostram, na prática, como decisões simples de engenharia de software podem reduzir de forma significativa a superfície de ataque de um sistema embarcado, mesmo em um estágio inicial de desenvolvimento.

Ainda assim, o sistema mantém vulnerabilidades em aberto que não foram tratadas nesta entrega, como a ausência de criptografia no tráfego HTTP, a falta de proteção contra reenvio de requisições (replay) e a exposição

do SSID e do token diretamente no código-fonte. Essas limitações são reconhecidas pela equipe e ficam registradas como recomendações para as próximas iterações do projeto, sobretudo à medida que o protótipo evoluir da máquina de lançar bolinhas de ping pong para a máquina de bolas de tênis da empresa parceira, cenário em que o sistema passará a operar em ambiente real e com maior exposição a terceiros.

De forma geral, o exercício de elaboração deste relatório reforçou, para a equipe, a importância de tratar a segurança como parte do processo de desenvolvimento desde as primeiras versões do sistema, e não como uma etapa posterior à entrega, contribuindo diretamente para os objetivos da disciplina de Redes de Computadores e Cibersegurança.